

EU Compliance Gaps — Action Plan

Audit date: 2026-08-31 · Codebase: v0.13.3 · Coverage: 48% (25/52)

Self-assessment against eIDAS 2.0 (EU 2024/1183), EUDIW ARF v2.0, ETSI EN/TS, NIS2, CRA.

Gap 1 — CRA Vulnerability Disclosure

Regulation: EU 2024/2847 Art. 11 · **Deadline:** 2026-09-11 · **Severity:** URGENT

SECURITY.md has a threat model but no structured vulnerability disclosure process per CRA.

Required: - Contact email or form for reporting vulnerabilities - Expected response time (≤ 72 h initial, ≤ 24 h for actively exploited) - Coordinated disclosure statement - ENISA notification channel for actively exploited vulnerabilities - Product security contact published in machine-readable format

Action: - [x] Add vulnerability reporting section to SECURITY.md (email, PGP key, response SLA) - [x] Add security.txt at .well-known/security.txt per RFC 9116 - [x] Document ENISA notification procedure for actively exploited vulns

Effort: 1 day

Gap 2 — Formal SBOM

Regulation: NIS2 Art. 21, CRA Art. 13 · **Deadline:** 2026-09-11 (CRA) · **Severity:** HIGH

Cargo.lock exists but is not a formal SBOM. CRA requires machine-readable software bill of materials.

Required: - CycloneDX or SPDX format SBOM - Generated per release, shipped with binary artifacts - Includes all transitive dependencies with versions and licenses

Action: - [x] Add cargo-cyclonedx or cargo-sbom to build pipeline → scripts/generate-sbom.sh - [x] Generate SBOM on each tagged release → sbom.cdx.json (921 components, CycloneDX 1.5) - [x] Include SBOM in Docker image and release artifacts → Dockerfile copies sbom.cdx.json to /app/

Effort: Half day

Gap 3 — Relying Party Registration

Regulation: CIR 2025/848 · **Deadline:** 2026-12-24 · **Severity:** HIGH

No RP registry or access certificate validation. Wallet ecosystem requires verifiers to be registered.

Required: - RP registration endpoint or integration with national RP registry - Access certificate validation before accepting presentation requests - RP metadata (name, purpose, data requested) disclosed to wallet user

Action: - [x] Design RelyingPartyRegistry with access certificate store → RelyingParty struct + VpRequestStore.relying_parties - [x] Add RP validation middleware to OID4VP endpoints → create_request returns 403 UNREGISTERED_RP - [x] Expose RP metadata in presentation request per ARF Topic 31 → client_metadata in response - [] Test against EUDIW reference implementation

Effort: 1-2 weeks

Gap 4 — Wallet Trust Evidence (WTE)

Regulation: ARF v2.0 Topic 38 · **Deadline:** 2026-12-24 · **Severity:** HIGH

WIA is implemented but WTE is the next-gen attestation mechanism defined in ARF v2.0. Supplements/replaces WIA for stronger wallet authentication.

Required: - WTE issuance and validation alongside WIA - WTE binding to credential requests - Key attestation chain verification

Action: - [x] Track ARF v2.0 Topic 38 final specification (iterating as of 2026) - [x] Implement verify_wte() parallel to existing verify_wia() → validates typ=wte+jwt, cnf binding, expiry, iat freshness, signature - [x] Update token endpoint to accept WTE alongside WIA → wallet_trust_evidence field on TokenRequest

Effort: 1 week (once spec stabilizes)

Gap 5 — External Identity Verification

Regulation: eIDAS Art. 26(b), CIR 2026/798 · **Severity:** HIGH

Biometric commitments are self-asserted SHA-256 hashes. Art. 26(b) requires capability to identify the signatory via trusted means. RA module exists but does not integrate with external identity providers.

Required: - Integration with at least one external identity verification service (eID, video-ident, or national eID scheme) - Identity proofing result linked to DID before AdES signing - Compliance with CIR 2026/798 for remote wallet onboarding

Action: - ☒ Define IdentityVerificationProvider trait (pluggable external IdP) → ra.rs - ☒ Implement adapter for at least one → SimulatedIdentityVerifier (test/dev), real adapters TBD per deployment - ☒ Link verified identity proofing to DID in RA store before allowing AdES → submit_and_verify() auto-approves on success - ☐ Update ELECTRONIC-SIGNATURE-COMPLIANCE.md Art. 26(b) caveat - ☐ Implement production adapter (ClaveÚnica, eID, video-ident) per deployment target

Effort: 2-3 weeks

Gap 6 — NIS2 Security Management Validated by CAB

Regulation: NIS2 Art. 21, EN 319 401 v3.2.1, CIR 2025/2160 · **Severity:** HIGH

Policy documents exist (PLAN-SEGURIDAD.md, PLAN-CONTINGENCIA.md, INCIDENT-RESPONSE-PLAN.md) but have not been validated by a Conformity Assessment Body.

Required: - Risk assessment per EN 319 401 v3.2.1 §6.3 - Security measures validated against NIS2 Art. 21(2) categories - Incident notification procedure (24h early warning, 72h full notification) - Annual review cycle documented

Action: - ☐ Review policy docs against EN 319 401 v3.2.1 checklist - ☐ Add NIS2 Art. 21(2) mapping to each policy document - ☐ Implement automated incident notification workflow (24h/72h timers) - ☐ Engage CAB for initial assessment when seeking QTSP status

Effort: 2 weeks (docs), CAB engagement is part of QTSP process

Gap 7 — Qualified Electronic Ledger

Regulation: eIDAS 2.0 Art. 45i, CIR 2025/2531 · **Severity:** MEDIUM

New trust service type created by eIDAS 2.0 — directly relevant to Goya as a blockchain/DLT. CIR 2025/2531 sets the reference standards.

Required: - Evaluate CIR 2025/2531 requirements against Goya's ledger architecture - Data integrity guarantees per Art. 45i (sequential ordering, time stamping, tamper evidence) - Qualified status requires QTSP certification (Gap 11)

Action: - [x] Obtain and analyze CIR 2025/2531 full text - [x] Map Goya's existing guarantees (BFT consensus, append-only, block hashing, TSA) to CIR requirements → docs/compliance/CIR-2025-2531-MAPPING.md - [x] Document gaps in a CIR-2025-2531-MAPPING.md — all 8 dimensions covered, no technical gaps - [x] Implement any missing technical requirements — none: all Art. 45i dimensions already implemented

Effort: 1-2 weeks analysis, implementation TBD **Result:** All 8 Art. 45i technical dimensions covered. Qualified status blocked only by QTSP certification (Gap 11).

Gap 8 — QERDS (Qualified Electronic Registered Delivery)

Regulation: eIDAS Art. 44, EN 319 521/522, CIR 2025/1944 · **Severity:** MEDIUM

No registered delivery protocol. Relevant if Goya handles contract delivery via LexChain.

Required: - Delivery receipt protocol per EN 319 522 - Proof of sending and proof of receipt with qualified time stamps - Non-repudiation of delivery

Action: - [x] Evaluate whether LexChain contract delivery constitutes ERDS — yes, contract delivery to counterparties is registered delivery - [x] Implement delivery receipt with TSA timestamp per EN 319 522 → `deliver()` + `acknowledge_delivery()` in `src/lexchain/engine.rs` - [x] Add `DeliveryReceipt` to LexChain state machine → new `Delivered` state after `FullySigned/Notarized`, `DeliveryReceipt` struct with `send_tsa_token` + `receipt_tsa_token`

Effort: 2 weeks (if needed) **Result:** ERDS protocol implemented with TSA-timestamped proof of sending and proof of receipt. 8 new tests.

Gap 9 — Qualified Archiving

Regulation: eIDAS 2.0 Art. 45g · **Severity:** MEDIUM

New trust service for long-term preservation of electronic data and signatures.

Required: - Preservation of signed data beyond certificate/algorithm validity period - Re-signing/re-timestamping before algorithm expiry - Archive format per ETSI TS 119 511 (when published)

Action: - [x] Track ETSI TS 119 511 development - [x] Evaluate existing CAdES-XL as foundation — using TSA re-timestamping approach instead (simpler, covers the requirement) - [x] Design archive re-signing service using `AlgorithmPolicy`

deprecation deadlines → `preserve_contract()` re-signs with new algorithm + TSA timestamp, `preserve_expiring()` sweeps contracts approaching deprecation deadline - [x] LexChain extended with preservation metadata → PreservationRecord struct with original/new algorithm, signature, pubkey, TSA token, reason

Effort: 2-3 weeks (once ETSI spec available) **Result:** `preserve_contract()` + `preserve_expiring()` implemented with AlgorithmPolicy integration. 5 new tests.

Gap 10 — QSCD Integration

Regulation: eIDAS Art. 29, Annex II · **Severity:** HIGH (blocks QES)

Software-only keys. HSM abstraction exists (`HsmConfig`, `SimulatedHsmProvider`) but no certified hardware.

Required: - Keys generated and stored in CC EAL4+ or EN 419 211 certified device - Key non-extractability guarantee - Sole control assurance via QSCD

Action: - [] Select QSCD hardware (Thales Luna, Utimaco, nCipher, YubiHSM) - [] Verify PQC support (ML-DSA-65) — most HSMs don't support FIPS 204 yet - [] Implement `HsmSigningProvider` adapter for chosen hardware via PKCS#11 - [] Test key generation, signing, non-extractability - [] Document QSCD security target reference

Effort: 4-6 weeks + hardware procurement

Blocker: Most HSM vendors don't yet support ML-DSA-65. Monitor Thales/ Utimaco PQC roadmaps.

Gap 11 — QTSP Certification

Regulation: eIDAS Art. 20-21, EN 319 403-1 · **Severity:** CRITICAL (blocks everything qualified)

No Qualified Trust Service Provider status. This is the master gate for QES, qualified seals, qualified timestamps, and cross-border legal equivalence.

Required: - Apply to national supervisory body (EU Member State) - Conformity assessment by accredited CAB per EN 319 403-1 - Meet all applicable EN 319 4xx policy requirements - Supervisory body grants qualified status and adds to EU Trusted List - Biennial re-audit

Action: - [] Choose target EU Member State for QTSP registration - [] Engage conformity assessment body (CAB) for pre-assessment - [] Close Gaps 1-10 as prerequisites - [] Prepare evidence package per EN 319 403-1 audit checklist - [] Submit conformity assessment report to supervisory body - [] Await qualified status grant + Trusted List inclusion

Effort: 12-18 months from first CAB engagement. Cost: €50K-150K.

Dependencies: Gaps 1-10 are all prerequisites. QSCD (Gap 10) is the hardest technical blocker.

Execution order

Priority	Gap	Deadline	Effort	Blocker for
P0	1. CRA Vulnerability Disclosure	2026-09-11	1 day	CRA compliance
P0	2. Formal SBOM	2026-09-11	0.5 day	CRA compliance
P1	3. RP Registration	2026-12-24	1-2 weeks	EUDIW ecosystem
P1	4. Wallet Trust Evidence	2026-12-24	1 week	EUDIW ecosystem
P1	5. External Identity Verification	—	2-3 weeks	AdES Art. 26(b)
P2	6. NIS2 Security Validated	—	2 weeks	QTSP
P2	7. Qualified Electronic Ledger	—	1-2 weeks	Qualified ledger status
P2	8. QERDS	—	2 weeks	If LexChain = ERDS
P2	9. Qualified Archiving	—	2-3 weeks	Long-term preservation
P3	10. QSCD Integration	—	4-6 weeks	QES
P3	11. QTSP Certification	—	12-18 months	Everything qualified

Start today: Gaps 1 and 2 (CRA deadline in 11 days). **Next sprint:** Gaps 3 and 4 (EUDIW deadline 2026-12-24). **Q4 2026:** Gaps 5-9. **2027:** Gaps 10-11 (QTSP + QSCD).